Adquisició física



ÍNDEX

Adquisició física **1**
1. Introducció **3**
2. Exercicis **4**
1. Crea un dispositiu virtual, amb AVD manager o Android Studio y executa'l amb l'emulador. 4
2. En la pràctica anterior hauríem d'haver vist que no es pot fer servir el mode recovery en l'emulador, per tant, tampoc el podem fer servir per fer una còpia de seguretat. Però podem fer la còpia (dd) i enviar-la al PC, o fer-ne una còpia a una tarja SD, i pasar-la al PC. Fent servir dd realitza les dues operacions. 7
3. En la máquina virtual host, instal-la kpartx i munta la imatge. Si dona problemes, busca informació i documenta l'error. 9
4. Fent servir strings i grep busca a les diferents imatges (al PC i/o a la tarja SD) els SMS's enviats. 10
5. En una màquina Windows, descarrega les últimes versions de autopsy i ftk imager. Busca la informació que hem generat al punt 1. 11
6. Des de la màquina virtual host, copia les basses de dades situades en /data/data/com.android.providers.telephony/databases. Busca els missatges i trucades que havies generat, amb Sqliteman i sqlite3. 14
7. En l'emulador, apunta el contingut d'un dels missatges generats i esborra'l. Torna a descarregar la base de dades de telefonia i sms's (Amb el missatge esborrat). Busca el missatge el·liminat. 17

1. Introducció

Un cop ja hem visualitzat com funciona internament un dispositiu mòbil i com s'estructura la informació a dintre d'aquest, aprendrem com intercanviar i buscar informació sensible dintre del dispositiu. Aquesta ens servirà per avaluar si pot haver-hi activitat sospitosa.

Aquesta activitat la podem diferenciar en funció de:

- Com es realitza l'atac
- Quin és l'objectiu del atac
- Cóm afecta a l'usuari

a. Com es realitza l'atac

Segons com es realitza l'atac es pot distingir entre:

- Malware: Virus, troians i/o aplicacions malicioses pensades per afectar algun dels objectius que veurem al següent punt. Aquests específicament son els que abordarem a partir d'aquesta pràctica sobre dispositius mòbils. En aquest apartat també podrem diferenciar l'atac en funció de quin serà el vector d'entrada del malware
  - Dia 0
  - Missatges maliciosos (Bluetooth, SMS, MMS, correu, …)
  - Ubicació i seguiment (Aplicació, access a dades, dades de 3rs, …)
- Atacs de xarxa: Els veurem en la UF corresponent. i tenen molta relació amb els atacs "Man in the middle"
- D'enginyeria Social: Quan ens extreuen dades amb tècniques específiques
- De força bruta: Intenció d'obtenir un accéss no autoritzat mitjançant prova i error.
- Atacs Man In The Middle (mitm)

b. Quin és l'objectiu

Podem diferenciar l'atac en funció de qui és l'objectiu d'aquest:

- Dades personals
- Phishing o Suplantació d'identitat: Amb enganys es pot obtenir informació de l'usuari que es pot utilitzar per fer activitats malintencionades.
- Accéss no autoritzat del dispositiu
- Ransomware: Es pot bloquejar el dispositiu i demanar un rescat
- Destrucció de dades

c. Com afecta al usuari

També, en funció de l'afectació a l'usuari, els atacs es poden diferenciar segons:

- Denegació de servei: S'hi inhabilita alguna funció del telèfon
- Comprometre informació privada: S'accedeix a algun tipus de dada sensible de l'usuari
- Dany físic al dispositiu: En el pitjor dels casos es pot malmetre l'us del dispositiu i deixar-lo inservible.

2. Exercicis

Com a continuació de la pràctica anterior (P1.1) obtindrem informació de l'emulador i la modificarem. Realitzarem diferents accions com:

- afegir contactes
- enviar missatges
- eliminar dades
- etc…

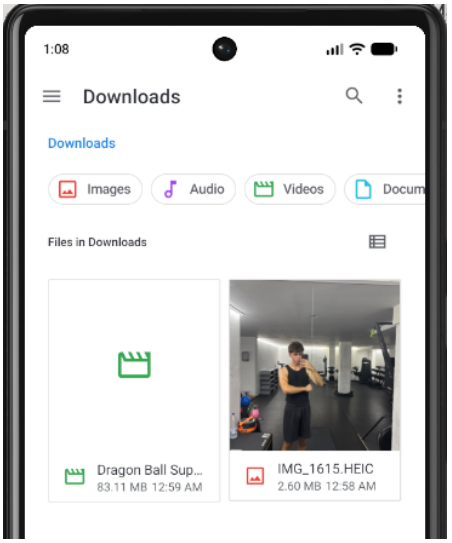
També aprendrem a fer una copia bit a bit, per fer servir aquesta informació i recuperar-la.

1. Crea un dispositiu virtual, amb AVD manager o Android Studio y executa'l amb l'emulador. (Entrega)



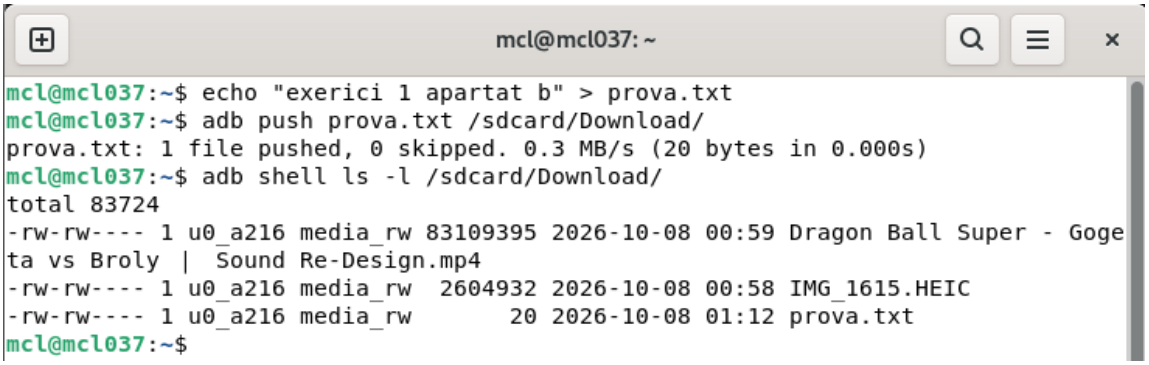
a. Afegeix fotos i/o vídeos: (que surtin a la galeria).

Afegeixo al dispositiu una captura de vídeo i una imatge de la pràctica anterior. Ho faig arrossegant els fitxers des de la carpeta del PC fins a la finestra de l'emulador.



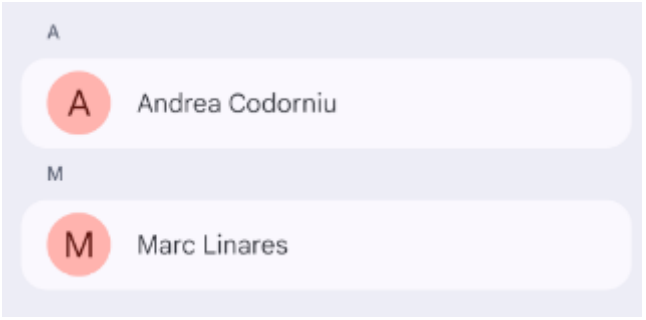
b. Afegeix algun arxiu. (Desde línea de comandes).

Creo el fitxer prova.txt amb echo, el pujo al dispositiu amb adb push a /sdcard/Download/ i comprovo amb adb shell ls -l que hi és.



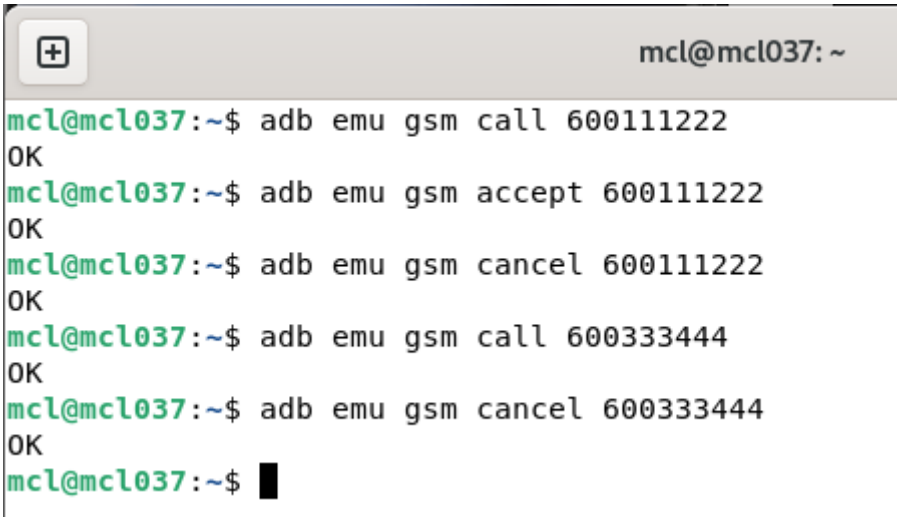
c. Afegeix contactes.

Afegeixo dos contactes a l'app Contactes: Andrea Codorniu i Marc Linares.



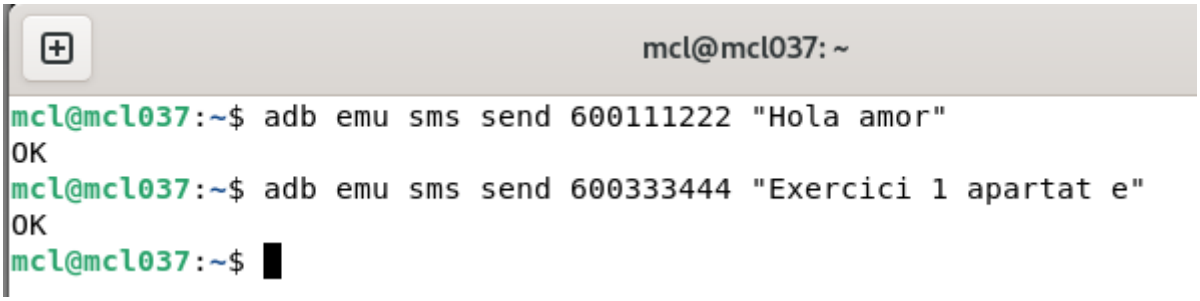
d. Simula diferents trucades.

Simulo trucades amb adb emu gsm call. Una la contesto amb accept i la penjo amb cancel, i l'altra la cancel·lo sense contestar-la. Les faig als números 600111222 i 600333444.



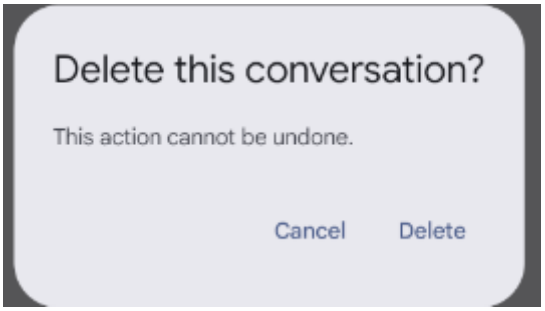
e. Simula l'enviament de SMS. (Guarda text del missatge enviat).

Simulo dos SMS amb adb emu sms send: "Hola amor" al 600111222 i "Exercici 1 apartat e" al 600333444.



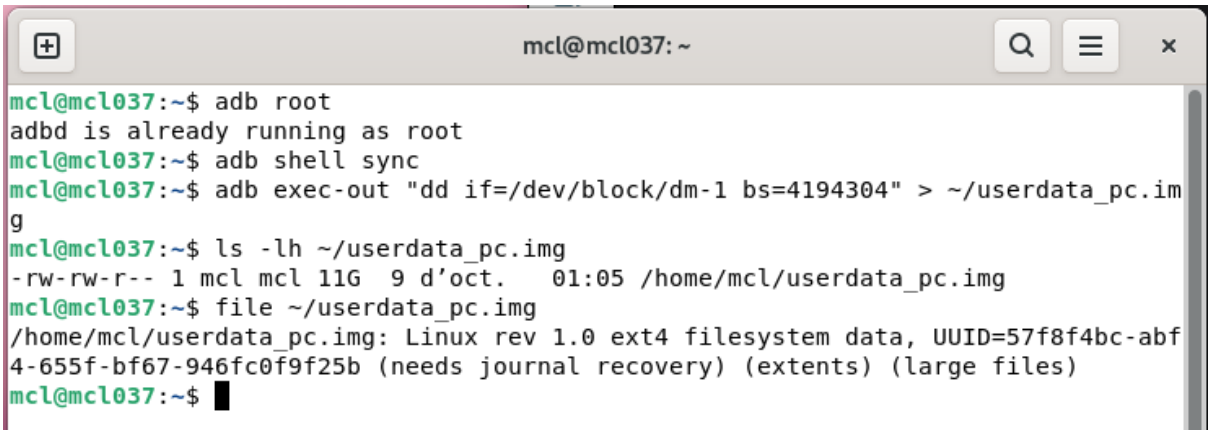
f. Elimina un dels missatges

A l'app Missatges elimino la conversa que conté "Hola amor".



2. En la pràctica anterior hauríem d'haver vist que no es pot fer servir el mode recovery en l'emulador, per tant, tampoc el podem fer servir per fer una còpia de seguretat. Però podem fer la còpia (dd) i enviar-la al PC, o fer-ne una còpia a una tarja SD, i pasar-la al PC. Fent servir dd realitza les dues operacions. (Check)

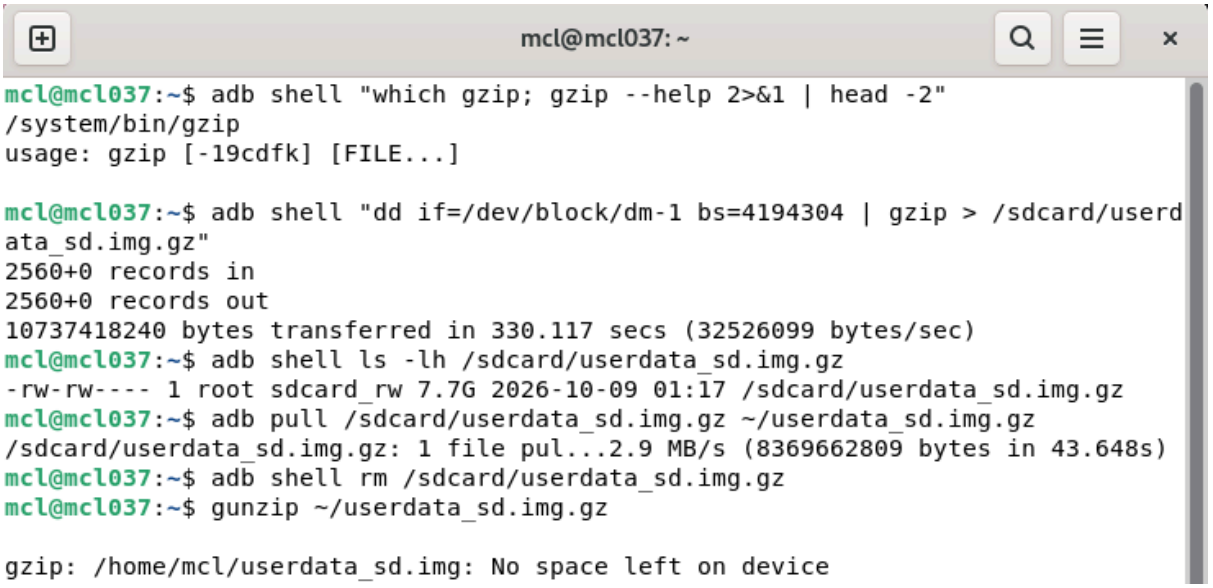
Per fer la primera còpia, activo l'accés d'administrador al dispositiu (adb root) i m'asseguro que totes les dades estan desades (adb shell sync). Després copio la partició on hi ha les dades i la guardo directament al PC com a userdata_pc.img, amb l'ordre dd. Comprovo que el fitxer ocupa uns 10 GB i que és un sistema de fitxers vàlid.

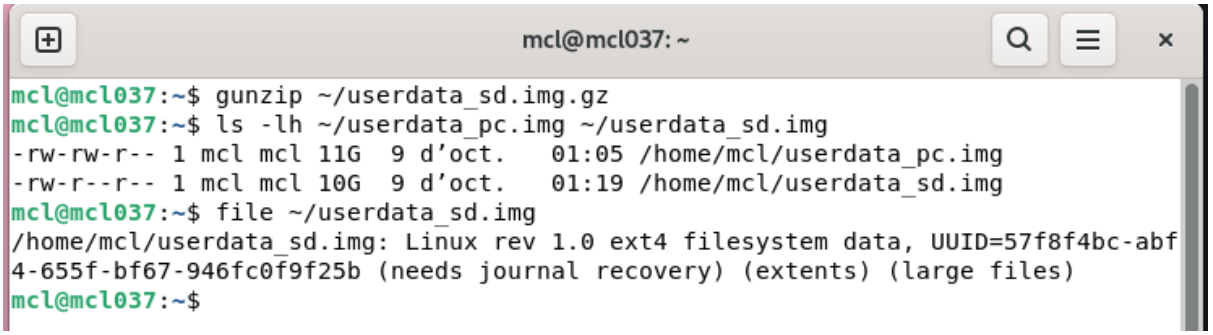


Per fer la segona còpia, guardo la imatge a la targeta SD de l'emulador i després la passo al PC. El problema és que la targeta SD ocupa el mateix espai que la resta de dades del dispositiu, i només hi tinc uns 9,5 GB lliures, així que la imatge de 10 GB no hi cap. Per això la comprimeixo mentre la copio, amb gzip (comprovo abans que el dispositiu el té). El fitxer comprimit ocupa 7,7 GB.

Passo el fitxer al PC amb adb pull i l'esborro de l'emulador. En descomprimir-lo amb gunzip surt l'error No space left on device, perquè al PC tampoc hi ha prou espai. Allibero espai esborrant imatges d'Android que no faig servir i torno a descomprimir-lo.

Finalment comprovo que tinc les dues imatges, userdata_pc.img i userdata_sd.img, i que la segona és un sistema de fitxers vàlid, igual que la primera.

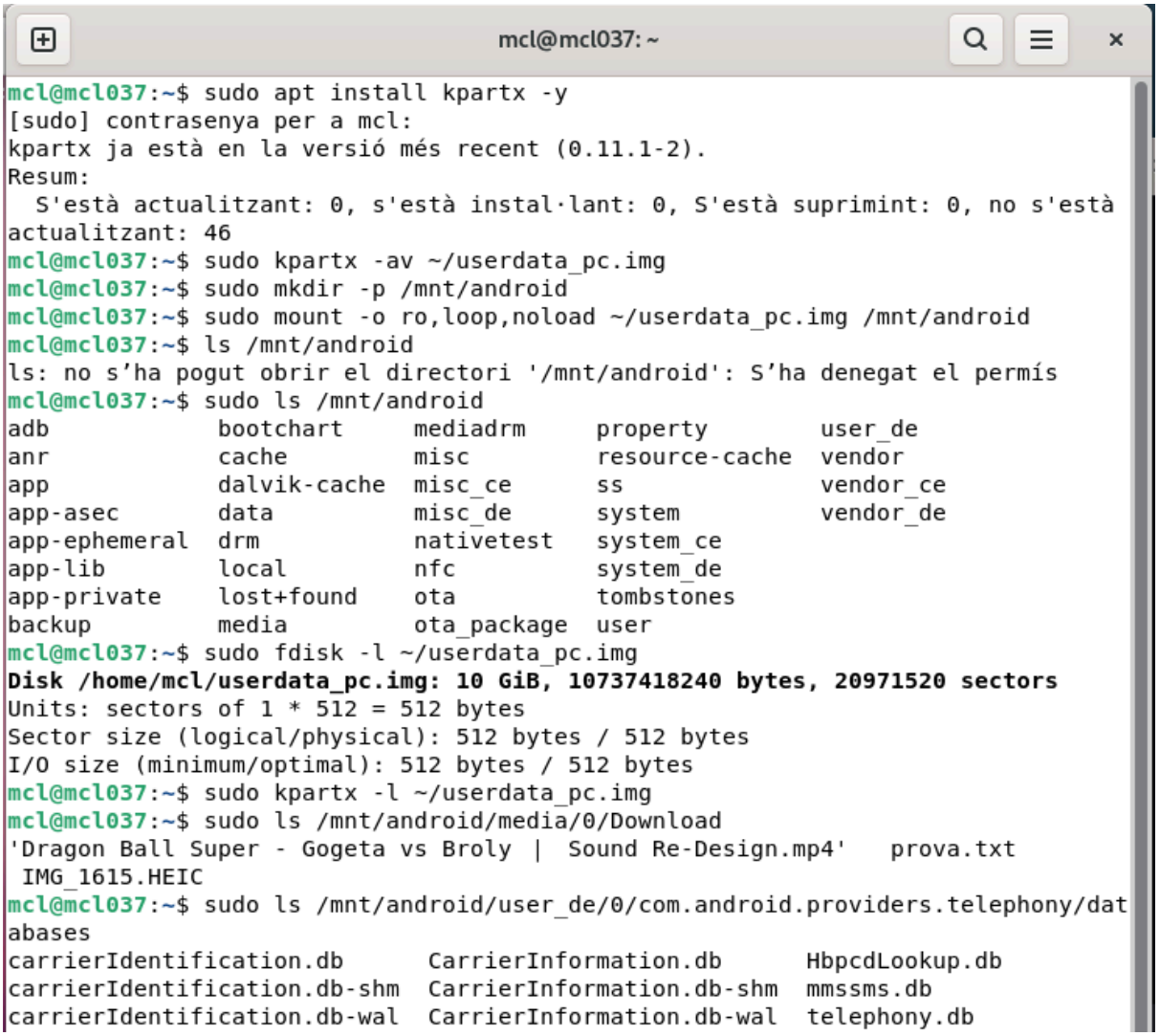




3. En la máquina virtual host, instal-la kpartx i munta la imatge. Si dona problemes, busca informació i documenta l'error. (Entrega)

Instal·lo kpartx amb apt i executo sudo kpartx -av ~/userdata_pc.img. No mostra cap sortida, perquè no hi ha cap partició per mapar. Ho confirmo amb fdisk -l i kpartx -l: la imatge no té taula de particions, ja que és un únic sistema de fitxers ext4. Per això la munto directament amb mount -o ro,loop,noload a /mnt/android.

Amb sudo ls veig l'estructura de /data. Comprovo que a media/0/Download hi ha el vídeo, la imatge i prova.txt, i que a la carpeta de telefonia hi ha mmssms.db.

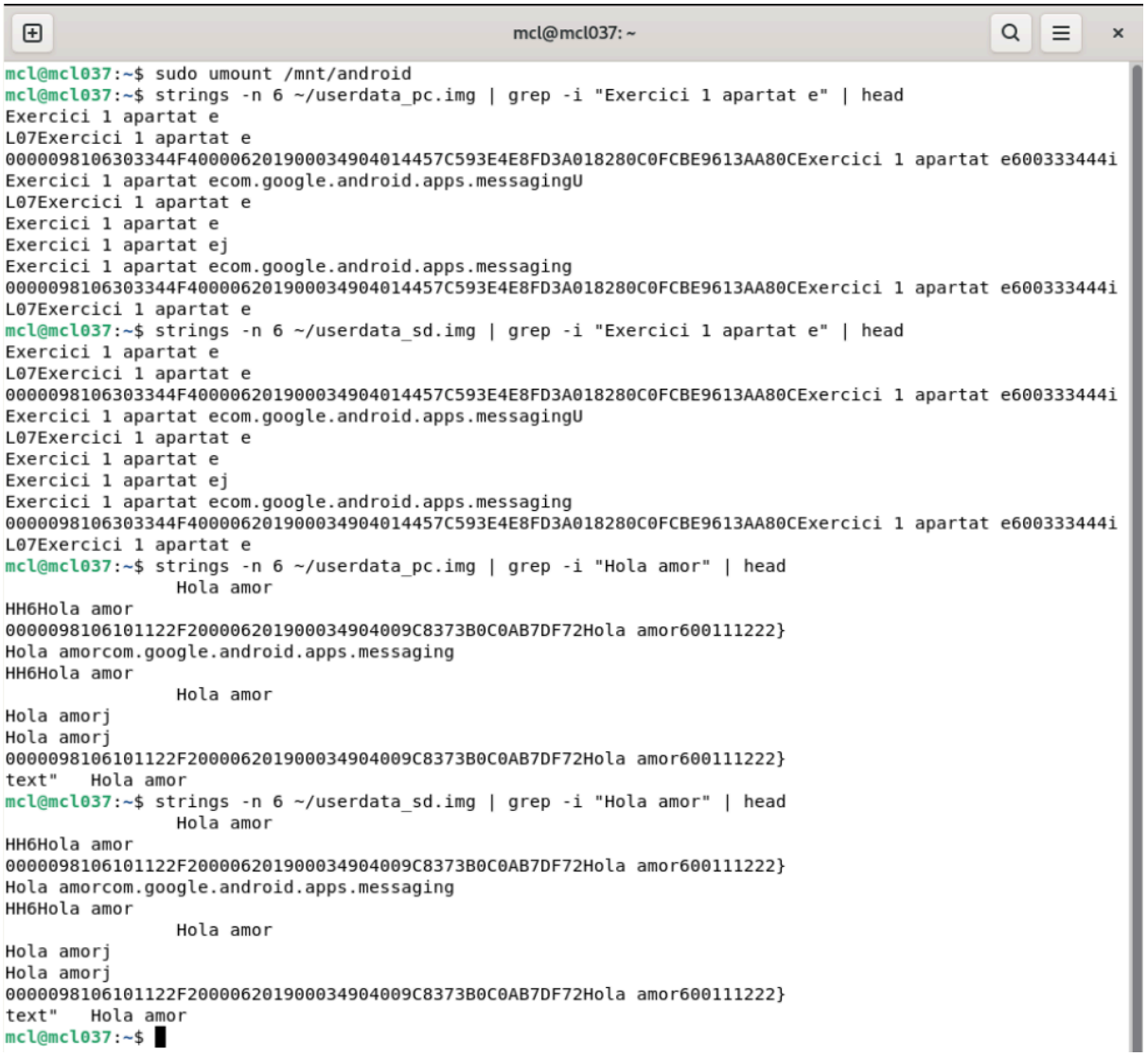


4. Fent servir strings i grep busca a les diferents imatges (al PC i/o a la tarja SD) els SMS's enviats.(Entrega)

Desmunto la imatge i executo strings -n 6 sobre userdata_pc.img i sobre userdata_sd.img, filtrant amb grep -i. Cerco “Exercici 1 apartat e” i “Hola amor”.

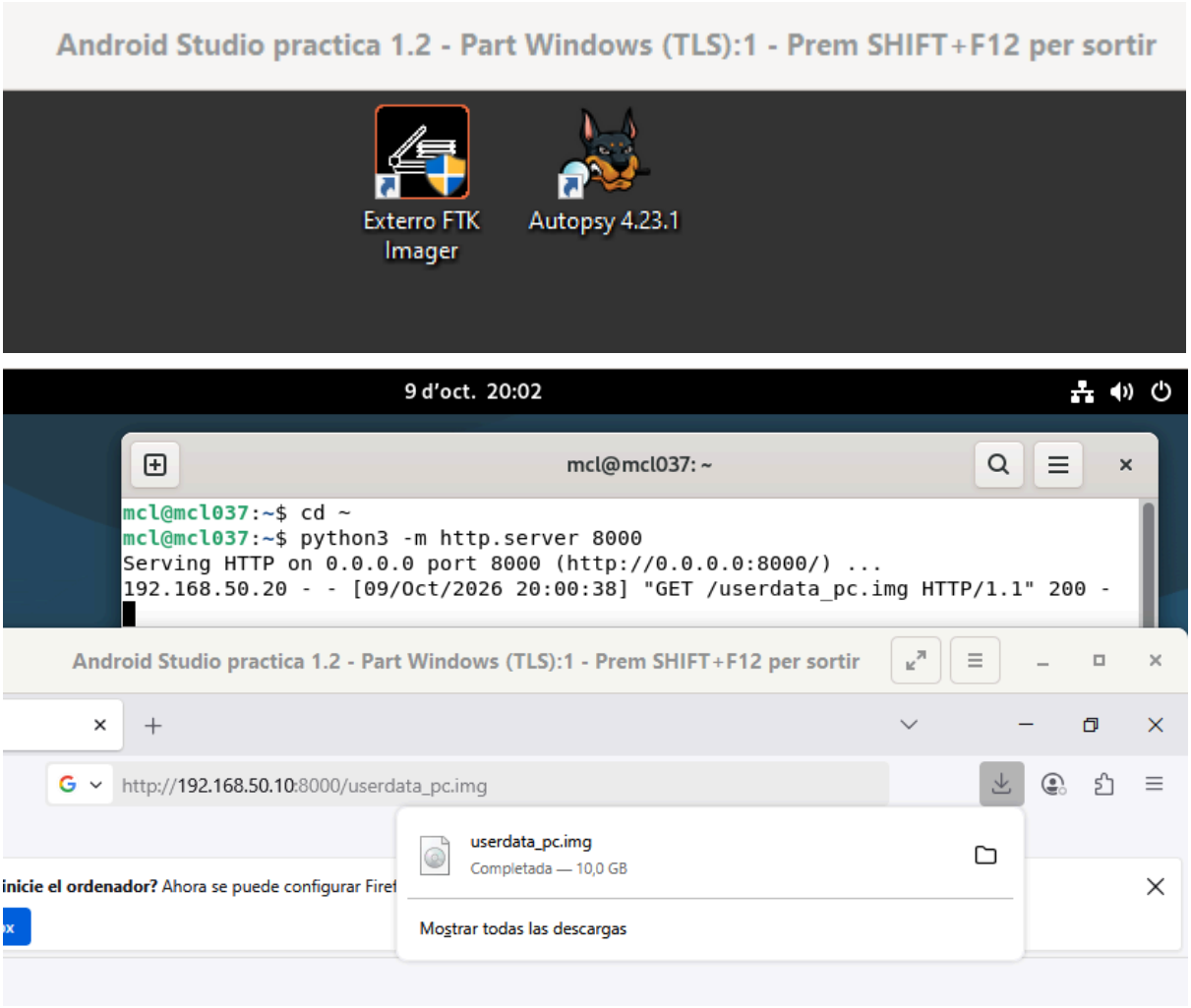
Tots dos missatges apareixen a les dues imatges, junt amb el número de telèfon (600333444 i 600111222) i amb referències a l’app de missatges de Google. Els resultats són idèntics en les dues imatges. “Hola amor” surt tot i haver-lo eliminat a l’exercici 1.f, cosa que indica que Android només el marca com a esborrat i en deixa restes al disc.

Cal tenir en compte que adb emu sms send simula la recepció d’un SMS, i per això a la base de dades consten com a rebuts (type = 1).

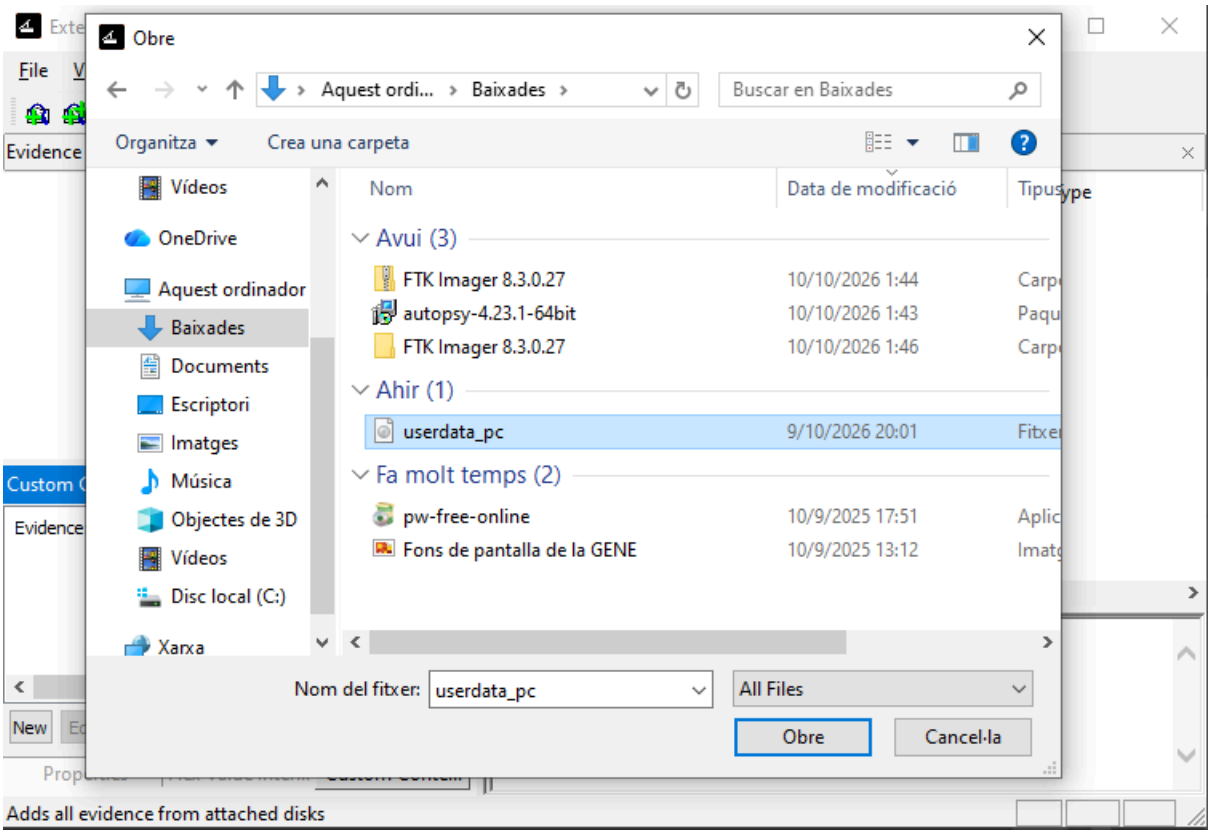


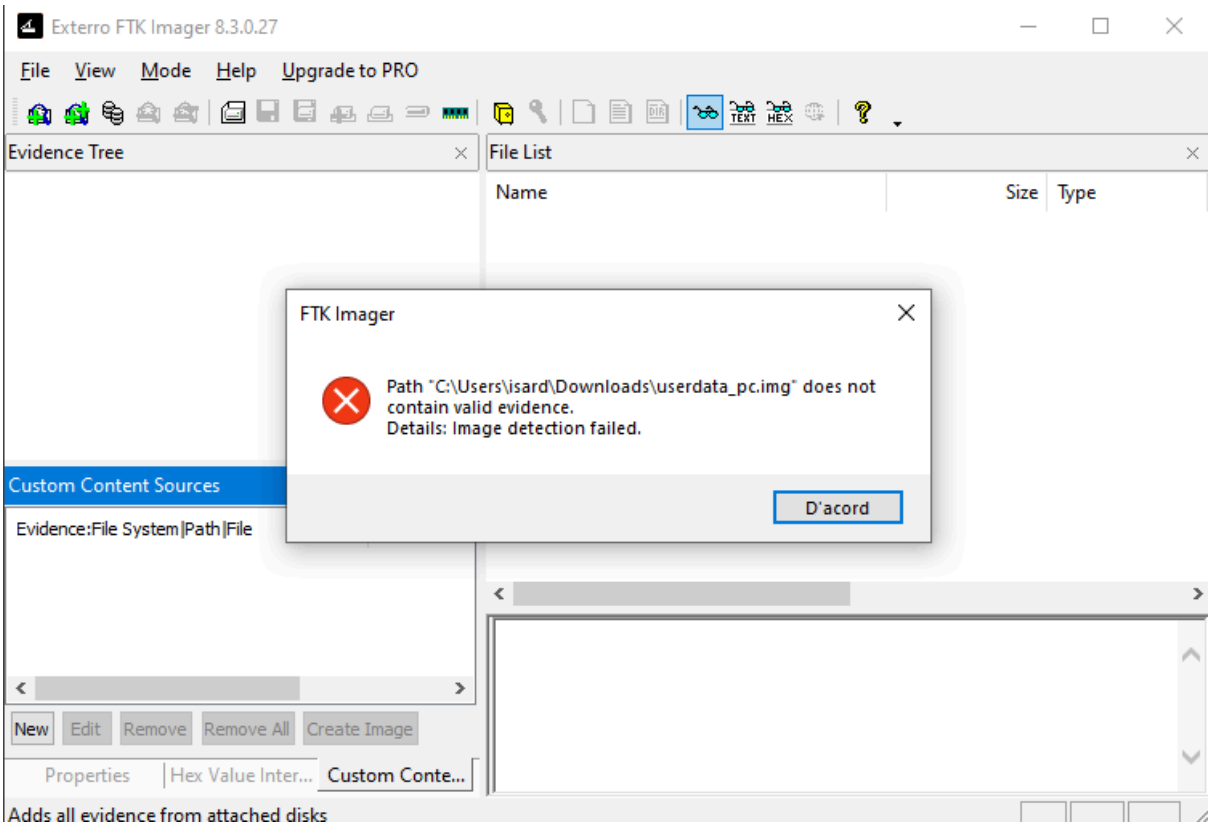
5. En una màquina Windows, descarrega les últimes versions de *autopsy* i *ftk imager*. Busca la informació que hem generat al punt 1.(Entrega)

Utilitzo una màquina virtual Windows 10 a ISARD. Com que les dues màquines són en xarxes diferents i no es veuen, les poso a la mateixa xarxa i els assigno IP manuals (192.168.50.10 a Linux i 192.168.50.20 a Windows). A Linux executo python3 -m http.server 8000 i des de Windows descarrego userdata_pc.img amb el navegador. Hi instal·lo FTK Imager i Autopsy.

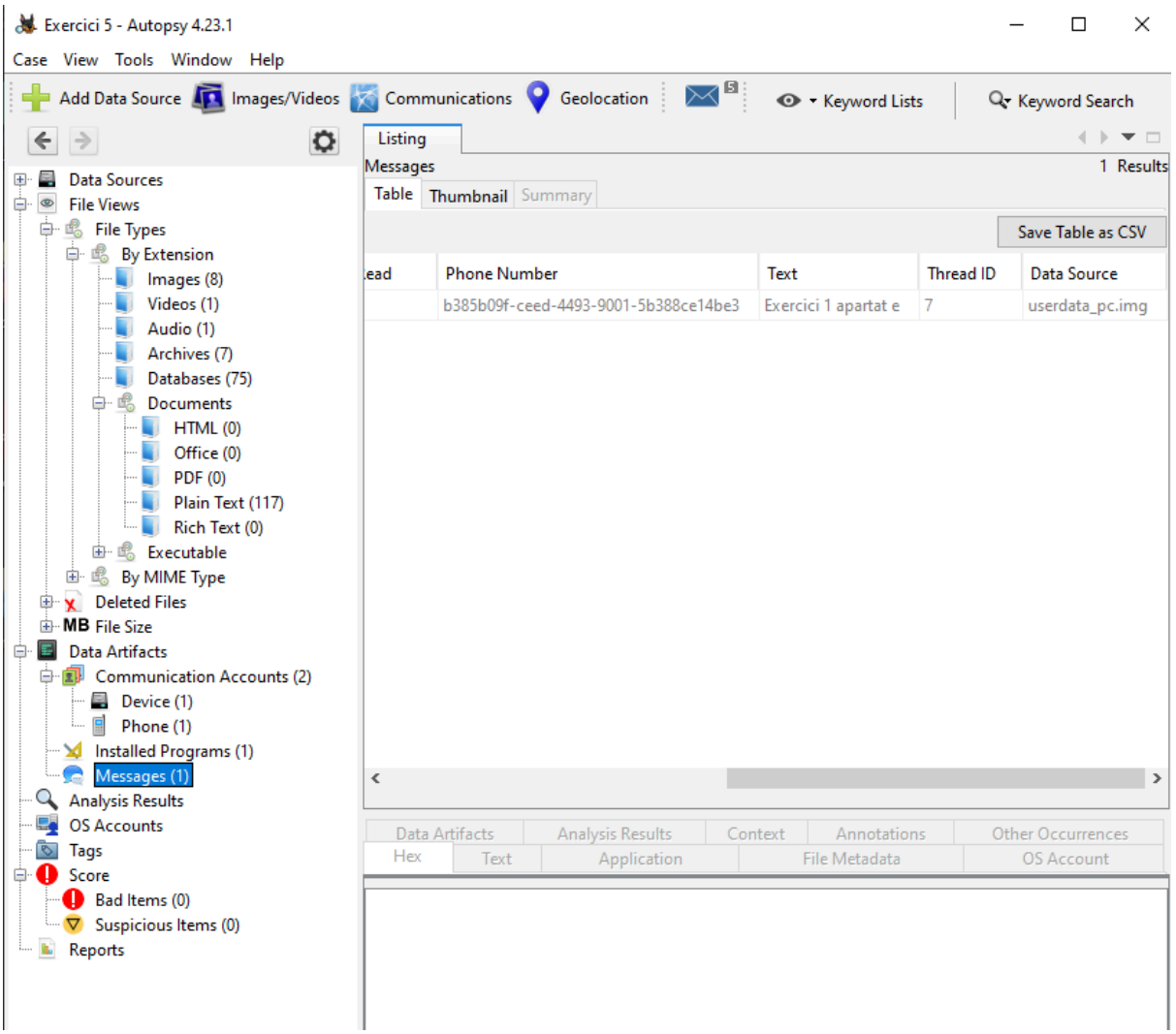


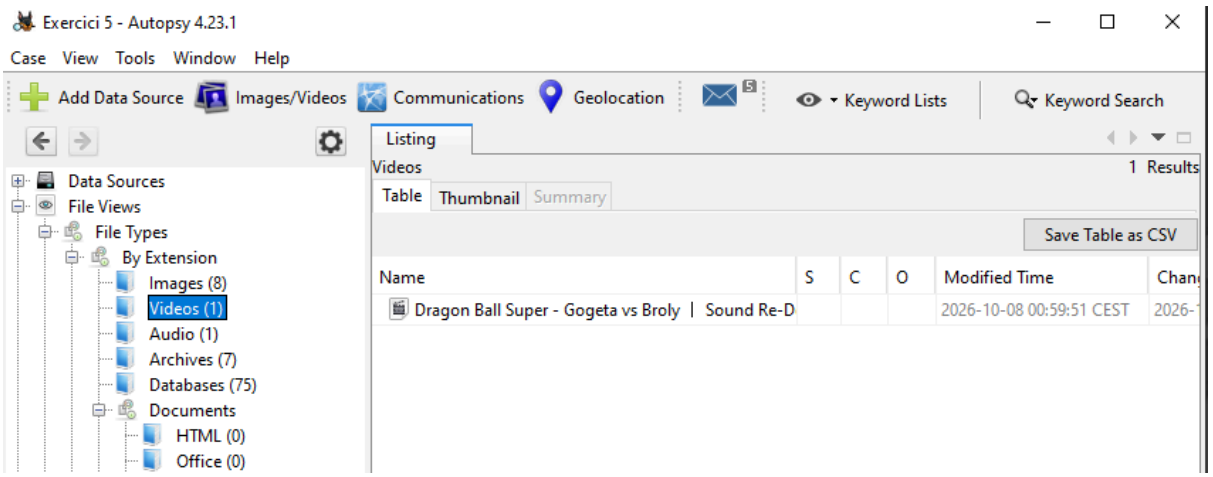
FTK Imager: En afegir la imatge, l'eina mostra l'error Image detection failed. Probablement és perquè la imatge és un ext4 sense taula de particions, que és el mateix motiu pel qual kpartx no hi troba res. No he pogut analitzar la imatge amb aquesta eina.

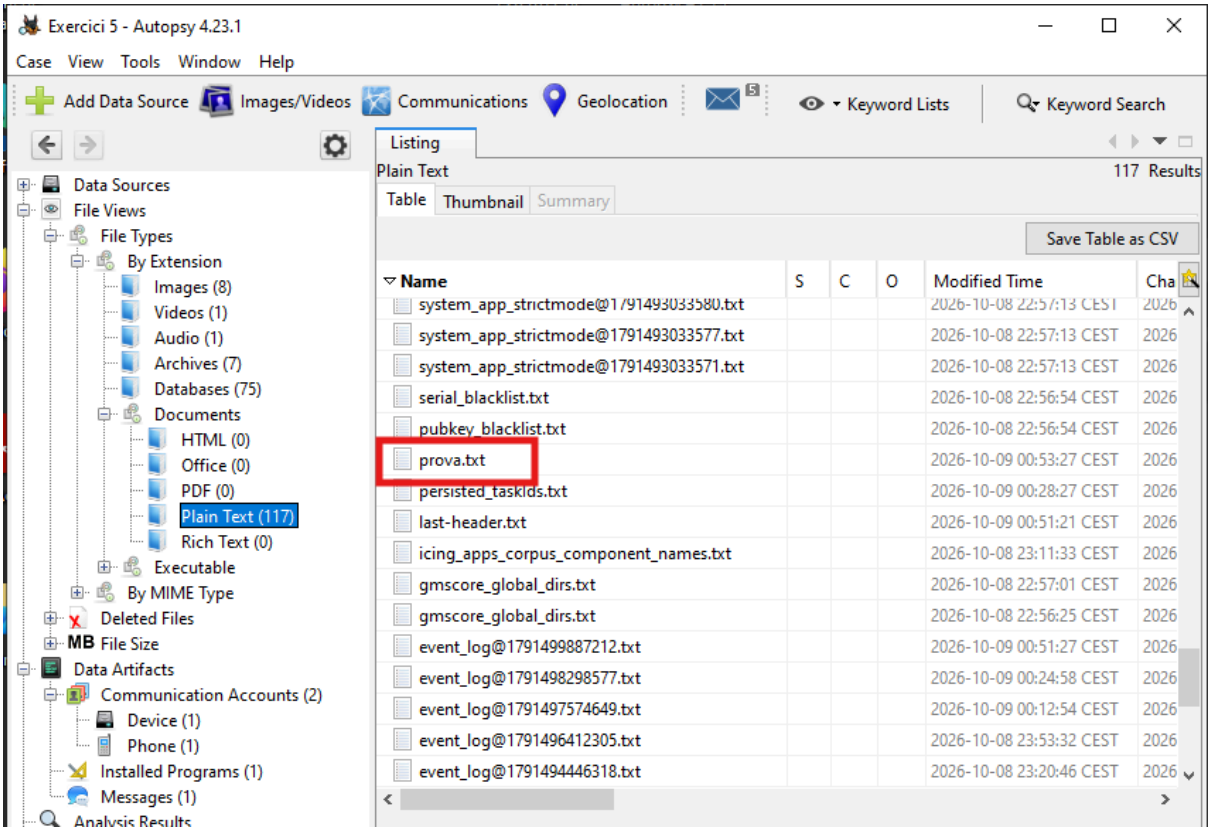




Autopsy: Creo el cas Exercici 5 i afegeixo la imatge. Hi trobo la informació generada a l'exercici 1:



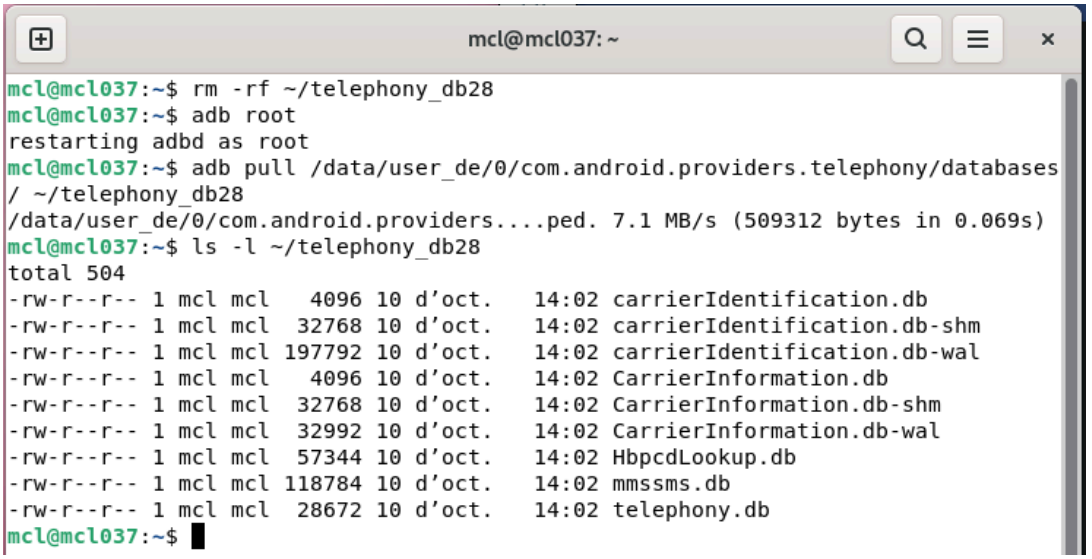


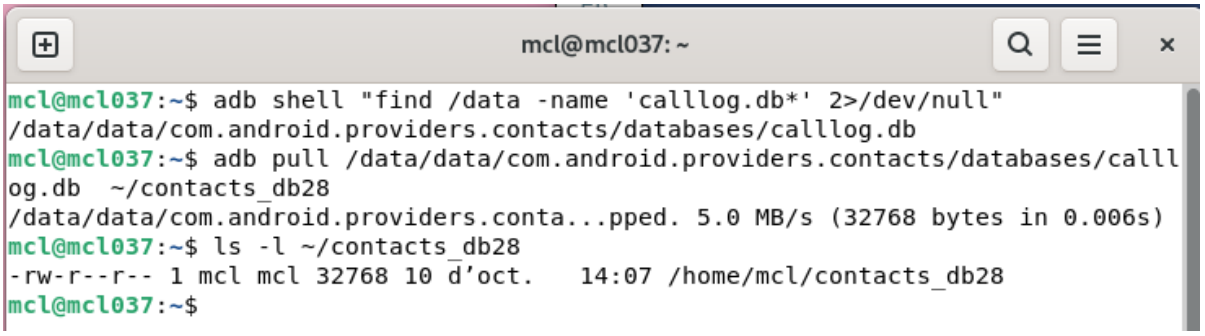


6. Des de la màquina virtual host, copia les basses de dades situades en /data/data/com.android.providers.telephony/databases. Busca els missatges i trucades que havies generat, amb Sqliteman i sqlite3.

Elimino una còpia anterior de les bases de dades i les torno a copiar al PC amb adb pull. En aquesta versió d'Android, la base de dades dels missatges és a /data/user_de/0/com.android.providers.telephony/databases/, i no a /data/data/... com diu l'enunciat. Comprovo amb ls -l que s'ha copiat, entre d'altres, el fitxer mmssms.db.

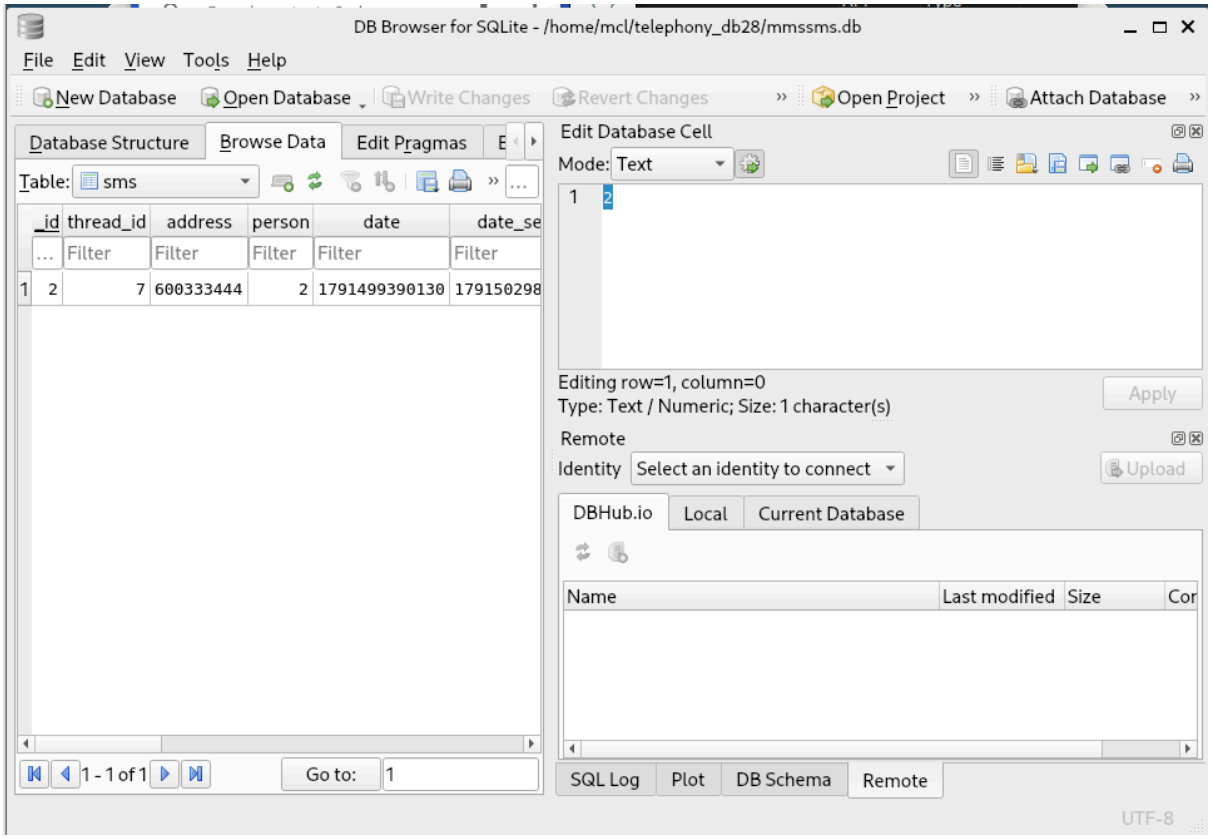
Les trucades que havia simulat al principi no es van registrar, així que les torno a simular de la mateixa manera. Després cerco el fitxer de trucades, calllog.db, i el copio també al PC.





a. Sqliteman es una interficie gràfica.(Entrega)

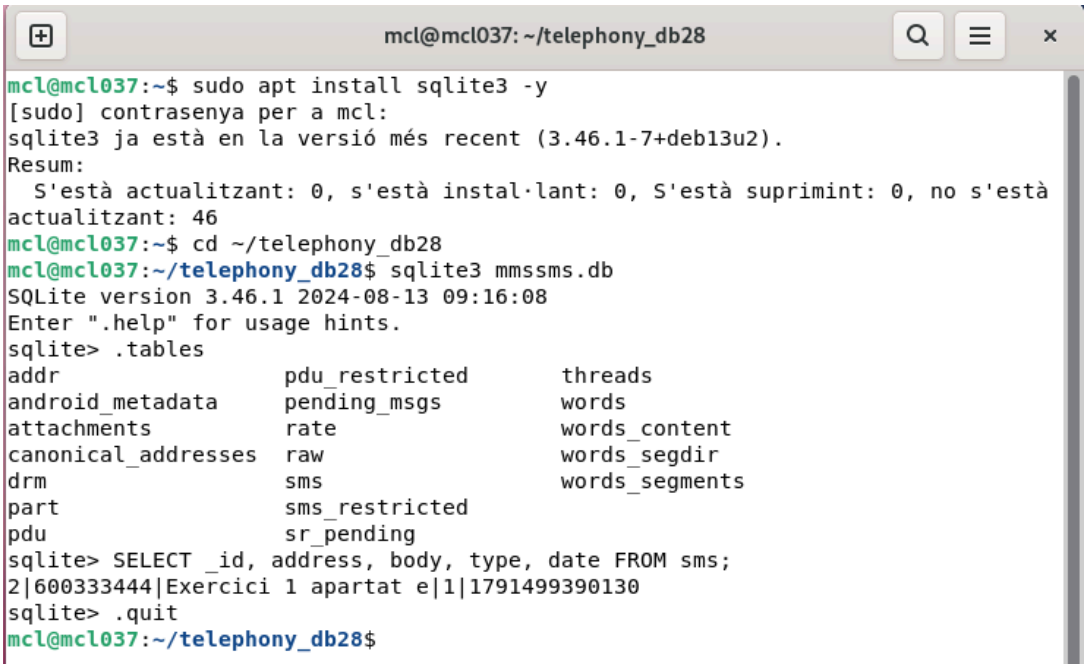
Sqliteman no es pot instal·lar: apt no el troba a Debian 13, snap no el té i la seva pàgina només l'ofereix per a Microsoft Store i Mac App Store, on tampoc el trobo. Faig servir DB Browser for SQLite, una eina gràfica equivalent. A la pestanya Browse Data de la taula sms es veu el missatge "Exercici 1 apartat e".

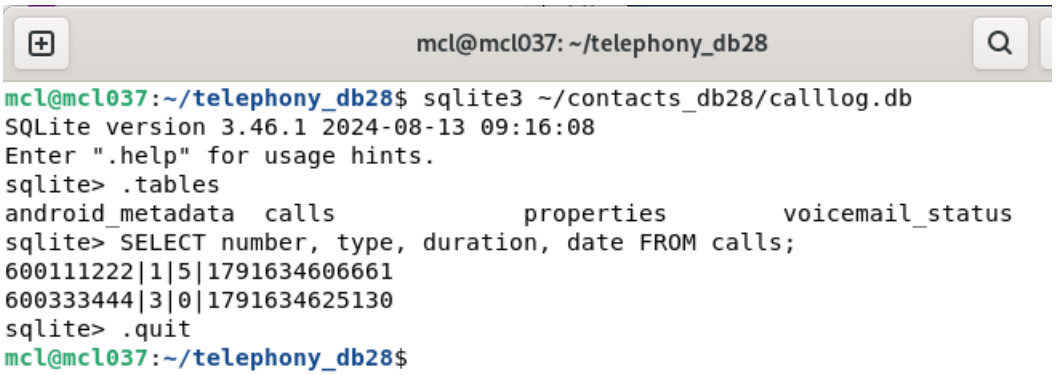


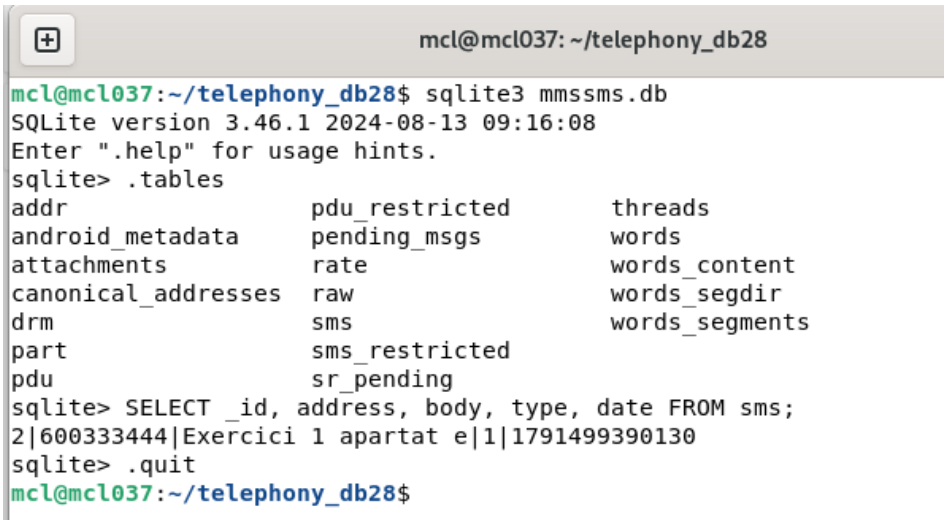
b. sqlite3 es de línea de comandes. => (Pista: .tables per mostrar les taules.)(Entrega)

Obro la base de dades dels missatges, mmssms.db, amb sqlite3 i amb .tables miro quines taules té. Després consulto la taula sms i hi surt el missatge "Exercici 1 apartat e", que és de tipus 1 (rebut). "Hola amor" no hi és, perquè l'he eliminat.

Faig el mateix amb la base de dades de trucades, calllog.db. La taula calls mostra la trucada que he contestat a 600111222 (tipus 1, 5 segons) i la que no he contestat a 600333444 (tipus 3).

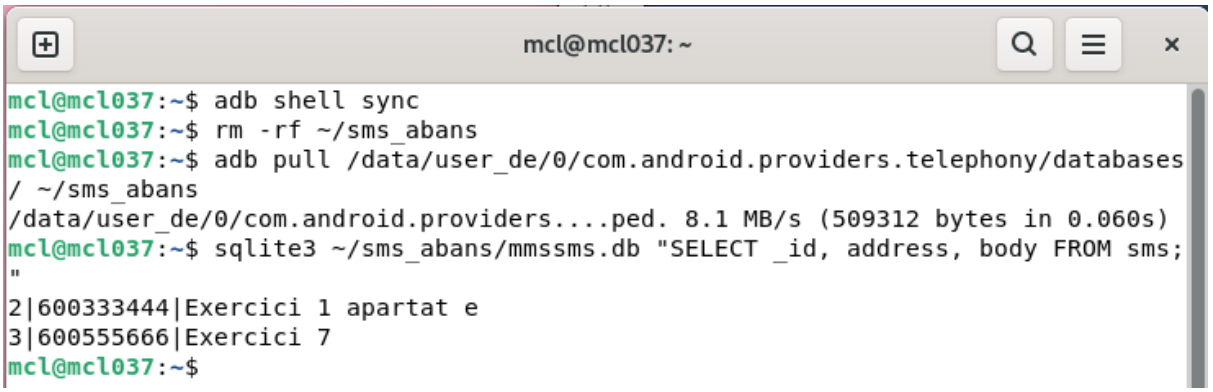






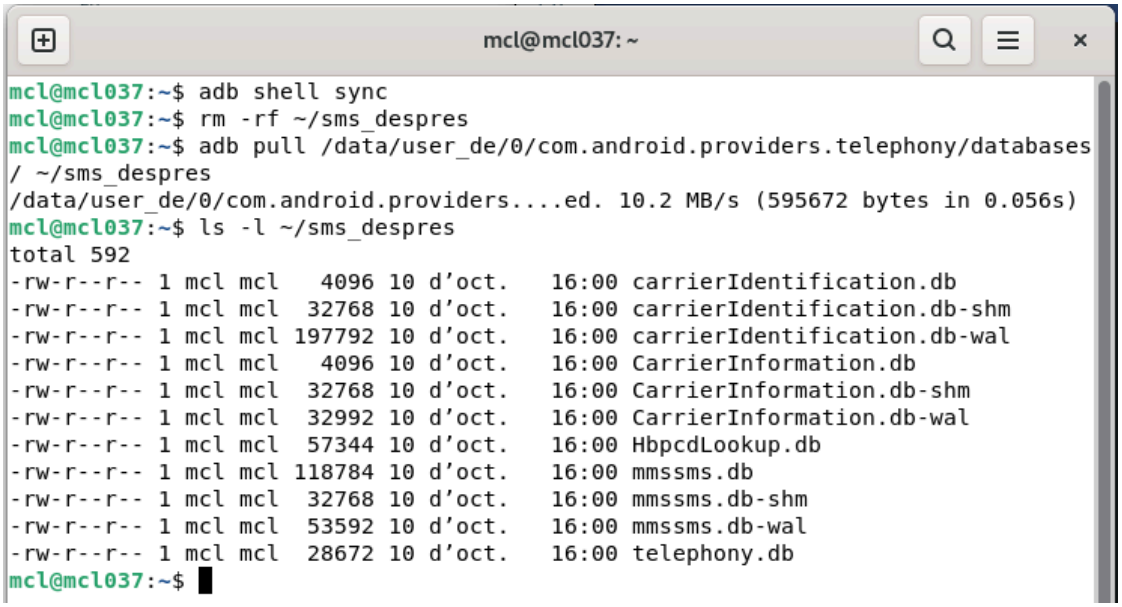
7. En l'emulador, apunta el contingut d'un dels missatges generats i esborra'l. (Entrega). Torna a descarregar la base de dades de telefonia i sms's (Amb el missatge esborrat). Busca el missatge el·liminat amb:

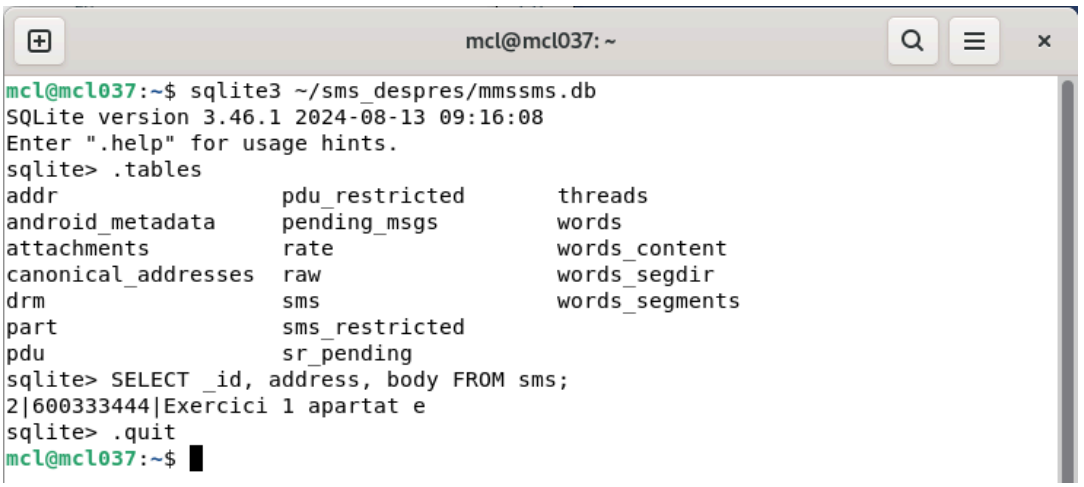
Envio un missatge nou amb adb emu sms send 600555666 "Exercici 7", que és el contingut que apunto. Baixo la base de dades abans d'esborrar-lo (sms_abans): el SELECT mostra dues files, "Exercici 1 apartat e" i "Exercici 7". Després l'elimino a l'app Missatges i torno a baixar la base de dades (sms_despres).



a. Amb l'sqlite3 o sqliteman ¿Es veu el missatge? (Check)

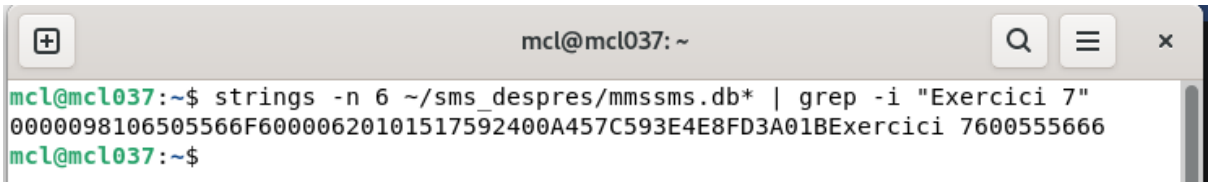
No es veu el missatge. A la taula sms només queda "Exercici 1 apartat e".





b. Amb l'ordre string ¿I ara? (Check)

Sí que es veu. Surt una coincidència, amb el número 600555666 al costat, mentre que a la còpia d'abans n'hi havia quatre.



c. Prova a buscar el missatge esborrat amb xxd (Check) i hexdump. (Check)

Amb les dues eines trobo el missatge esborrat dins del fitxer mmssms.db, i el resultat és el mateix amb totes dues. El text surt partit en dues línies ("Exe" i "rcici 7"), perquè aquestes eines només mostren una part del contingut a cada línia. Per això no cerco el text sencer, sinó només "ici 7", i demano que també em mostri les línies de al voltant.

